

Security+ 4.8 · Digital Forensics

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.8 — Digital Forensics (9:54)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Forense: data collection (VOLÁTIL primeiro — RAM→cache→disco→backup); legal hold (preserva evidência — notifica o jurídico); chain of custody (quem tocou/ quando — sem isso a evidência não vale em tribunal).

Highlights que a prova cobra

- Ordem de volatilidade: RAM primeiro (perde ao desligar)
- Chain of custody: o registro formal de cada ação com a evidência

Dicas de prova & Cenários Típicos

- 'documenting who handled the evidence'=chain of custody

Cenário clássico de exame: 'registro que mapeia a evidência do incidente até o tribunal'=chain of custody.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 4.8 — Digital Forensics)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Coletando evidência forense, a 'ordem de volatilidade' manda capturar primeiro:

- A) O HD / disco
- B) A memória RAM (dados voláteis)
- C) Os backups em fita
- D) Os logs impressos

2. Registro que documenta quem tocou uma evidência, quando e por quê (forense):

- A) Cadeia de custódia
- B) Ordem de volatilidade
- C) Retenção de log
- D) Não-repúdio

3. Cenário corporativo (Digital Forensics): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'Ordem de volatilidade: RAM primeiro (perde ao desligar)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Ordem de volatilidade: RAM primeiro (perde ao desligar)...

4. Cenário corporativo (Digital Forensics): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'Chain of custody: o registro formal de cada ação com a evidência'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Chain of custody: o registro formal de cada ação com a evidência...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Digital Forensics): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'documenting who handled the evidence'=chain of custody'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'documenting who handled the evidence'=chain of custody...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Digital Forensics): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'registro que mapeia a evidência do incidente até o tribunal'=chain of custody.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'registro que mapeia a evidência do incidente até o tribunal'=chain of cust...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Digital Forensics): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'Ordem de volatilidade: RAM primeiro (perde ao desligar)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Ordem de volatilidade: RAM primeiro (perde ao desligar)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Digital Forensics): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'Chain of custody: o registro formal de cada ação com a evidência'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Chain of custody: o registro formal de cada ação com a evidência...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Digital Forensics): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'documenting who handled the evidence'=chain of custody'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'documenting who handled the evidence'=chain of custody...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Digital Forensics): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'registro que mapeia a evidência do incidente até o tribunal'=chain of custody'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'registro que mapeia a evidência do incidente até o tribunal'=chain of cust...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — A memória RAM (dados voláteis).

✓ **Por que está certa:** A alternativa correta é capturar primeiro a memória RAM (dados voláteis). A ordem de volatilidade é um princípio fundamental da forense digital, estabelecido no RFC 3227 e cobrado pela CompTIA Security+ SY0-701 no domínio de Investigação de Incidentes e Forense. Ela determina que as evidências devem ser coletadas da mais volátil para a menos volátil, pois dados voláteis desaparecem rapidamente com o desligamento ou reinício do sistema. A memória RAM contém artefatos críticos como processos em execução, conexões de rede ativas, chaves de criptografia, malware residente apenas em memória (fileless), credenciais em texto claro e histórico de comandos. Se o sistema for desligado antes da captura da RAM, essas evidências são perdidas irremediavelmente. Portanto, a RAM deve ser adquirida antes de discos, backups ou logs impressos, que são menos voláteis e podem ser preservados posteriormente.

✗ **Por que as outras estão erradas:**

- *O HD / disco:* O disco rígido (HD) ou SSD é um meio de armazenamento não volátil, cujos dados persistem após o desligamento do sistema. Embora seja uma fonte rica de evidências (arquivos, logs, registro, artefatos de sistema), ele é menos volátil que a RAM. A ordem de volatilidade exige que a RAM seja capturada primeiro, pois desligar a máquina para preservar o disco destruiria as evidências voláteis. Portanto, capturar o disco antes da RAM viola o princípio forense e pode levar à perda de dados cruciais.
- *Os backups em fita:* Backups em fita são cópias de dados armazenadas off-line ou em mídia removível, com altíssima persistência e baixa volatilidade. Eles são relevantes para recuperação, mas não contêm o estado volátil do sistema no momento do incidente. Na ordem de volatilidade, fitas estão entre os últimos itens a serem coletados, pois não se degradam rapidamente. Priorizá-las sobre a RAM seria um erro grave, pois os dados voláteis seriam perdidos enquanto se manipulam mídias de backup.
- *Os logs impressos:* Logs impressos em papel são evidências físicas não voláteis, que persistem indefinidamente se armazenadas corretamente. Eles podem conter informações úteis, mas representam um instantâneo estático e limitado, muitas vezes já filtrado ou resumido. Na ordem de volatilidade, documentos impressos são coletados por último, pois não sofrem alteração espontânea. Capturá-los antes da RAM desviaria o foco do que realmente se perde rapidamente, comprometendo a integridade da investigação.

2) A — Cadeia de custódia.

✓ **Por que está certa:** A cadeia de custódia é um registro documental cronológico que rastreia toda a manipulação de uma evidência digital ou física, desde sua coleta até sua apresentação em juízo ou descarte. Ela registra quem coletou, quem transferiu, quem recebeu, quando, onde, por quê e em quais condições a evidência foi mantida. Esse registro é essencial para garantir a integridade e a admissibilidade da evidência em processos legais ou disciplinares, pois demonstra que a evidência não foi alterada, contaminada ou substituída. Sem uma cadeia de custódia íntegra, a evidência pode ser considerada inadmissível ou ter seu valor probatório questionado.

✗ **Por que as outras estão erradas:**

- *Ordem de volatilidade:* A ordem de volatilidade é um princípio forense que orienta a coleta de evidências na sequência da mais volátil para a menos volátil (ex.: memória RAM, cache, conexões de rede, disco, backups). Ela define a prioridade de aquisição para evitar perda de dados que desaparecem ao desligar o sistema. Não é um registro de quem tocou na evidência, quando ou por quê; é uma diretriz metodológica de coleta, não um documento de rastreamento de custódia.
- *Retenção de log:* Retenção de log refere-se às políticas e práticas de armazenar registros de

eventos (logs) por um período determinado, conforme requisitos legais, regulatórios ou operacionais. Isso garante que informações de auditoria estejam disponíveis para investigações futuras. No entanto, a retenção de log não documenta a cadeia de custódia de uma evidência específica; ela apenas define por quanto tempo os logs são mantidos. A cadeia de custódia é um registro separado e detalhado sobre a manipulação da evidência, não sobre a duração de armazenamento de logs.

- *Não-repúdio*: Não-repúdio é uma propriedade de segurança que garante que uma parte não possa negar a autoria de uma ação ou a origem de uma mensagem, geralmente implementada por assinaturas digitais e certificados. É um conceito de segurança da informação relacionado à autenticidade e integridade, não um registro forense de custódia. Embora a cadeia de custódia possa usar mecanismos de não-repúdio para assinar registros, os dois conceitos são distintos: não-repúdio é uma garantia criptográfica, enquanto cadeia de custódia é um processo documental de rastreamento físico e lógico.

3) D — Implementar a solução correspondente: Ordem de volatilidade: RAM primeiro (perde ao desligar)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Digital Forensics): Ordem de volatilidade: RAM primeiro (perde ao desligar).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) A — Implementar a solução correspondente: Chain of custody: o registro formal de cada ação com a evidência....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Digital Forensics): Chain of custody: o registro formal de cada ação com a evidência.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) C — Implementar a solução correspondente: 'documenting who handled the evidence'=chain of custody....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Digital Forensics): 'documenting who handled the evidence'=chain of custody.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) B — Implementar a solução correspondente: 'registro que mapeia a evidência do incidente até o tribunal'=chain of cust....

- ✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Digital Forensics): 'registro que mapeia a evidência do incidente até o tribunal'=chain of custody..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: Ordem de volatilidade: RAM primeiro (perde ao desligar)....

- ✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Digital Forensics): Ordem de volatilidade: RAM primeiro (perde ao desligar).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: Chain of custody: o registro formal de cada ação com a evidência....

- ✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Digital Forensics): Chain of custody: o registro formal de cada ação com a evidência.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) C — Implementar a solução correspondente: 'documenting who handled the evidence'=chain of custody....

- ✓ Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Digital Forensics): 'documenting who handled the evidence'=chain of custody.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: 'registro que mapeia a evidência do incidente até o tribunal'=chain of cust....

- ✓ Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Digital Forensics): 'registro que mapeia a evidência do incidente até o tribunal'=chain of custody..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

